

Cyber Tabletop Exercise

SWIFT Workstation Compromise and Suspected Fraudulent Transfers

Enhanced Facilitator Guide

Scenario source	Structured STIX bundle and draft TTX provided by user
Revision basis	Evaluation feedback integrated into an improved exercise design
Exercise type	Facilitated tabletop exercise
Audience	Executive, operational, treasury/payments, fraud, legal/compliance, and technical response teams
Recommended duration	90 minutes; 120-minute extended option available
Classification	Internal use
Version	Enhanced version 2.0

Revision focus
This version preserves the original SWIFT payment fraud scenario while adding a precise pre-fraud technical attack lifecycle, objective success metrics, observer criteria, clarified decision ownership, and a stronger final MITRE ATT&CK mapping.

Facilitation outcome

- Validate how the organization identifies and suppresses suspicious SWIFT payment activity.
- Exercise decision-making between technical containment and payment continuity.
- Test fraud-recovery coordination with correspondent institutions under time pressure.
- Confirm safe restoration criteria for a high-trust payment environment.

Contents

1. Exercise Overview
2. Exercise Objectives
3. Scope
4. Participants and Roles
5. Rules of Engagement
6. Scenario Background and Threat Narrative
7. Key Scenario Facts and Added Assumptions
8. Technical Attack Lifecycle and Evidence Package
9. Evaluation Criteria and Success Metrics
10. Exercise Timeline and Injects
11. Key Decision Points
12. Technical and Business Impacts
13. Facilitator Guide
14. Debrief and Lessons Learned
15. Glossary
16. Optional Visuals for Facilitation
17. MITRE ATT&CK Mapping

Use of this guide

The facilitator should release inject information progressively. The technical attack lifecycle is included to improve realism and cyber accuracy, but participants should not receive all technical facts at the start of the exercise.

1. Exercise Overview

This tabletop exercise simulates a financially motivated intrusion affecting a bank's SWIFT-connected treasury payment environment. Participants are presented with suspicious cross-border payment messages queued from a high-trust SWIFT-connected workstation outside normal business patterns. The scenario tests containment of payment fraud risk, verification of queued payment messages, coordination with counterpart institutions, executive decision-making under uncertainty, and safe restoration of SWIFT-related operations.

The exercise is derived from a structured STIX scenario describing a banking organization operating SWIFT-connected treasury workflows, a crime-syndicate-style payment fraud intrusion crew, an attack pattern involving abuse of a compromised SWIFT-connected workstation, and decision-focused injects related to payment isolation and recall actions.

This enhanced version adds explicit technical facts for how the actor obtained and abused access before fraud execution. These added facts are marked as exercise assumptions and are used to support realistic technical discussion and a non-speculative ATT&CK mapping.

Attribute	Exercise design
Exercise mode	Facilitated discussion; no live system actions
Primary scenario risk	Unauthorized high-value SWIFT payment messages created, queued, or released using a compromised high-trust workstation
Core tension	Rapid isolation and payment suppression versus continuity of legitimate, time-sensitive treasury operations
Primary decision owners	SOC for technical containment; Treasury and Fraud for payment validation/recall; Legal/Compliance for notification and reporting; Executive/Crisis Lead for risk acceptance and business-wide payment interruption
Recommended duration	90 minutes: 10-minute introduction, 70-minute inject sequence, 10-minute debrief

2. Exercise Objectives

Core objectives

- Assess how quickly suspicious SWIFT payment activity can be identified, verified, and suppressed.
- Validate decision-making authority for isolating high-trust payment endpoints, SWIFT gateways, and associated credentials.
- Test coordination between SOC, treasury operations, fraud/financial crime, legal/compliance, and executive leadership.
- Evaluate escalation thresholds for executive notification, correspondent-bank coordination, regulatory engagement, and board-level awareness.
- Confirm how manual or break-glass payment procedures are invoked during a containment event.
- Identify evidence preservation and recovery requirements before reconnecting SWIFT-connected systems.
- Capture lessons learned for fraud controls, queue review procedures, privileged access, anomaly detection, and interbank recall readiness.

Audience-specific objectives

Audience	What this exercise should test
Executive / Crisis Management	Ability to approve risk-based containment, accept business impacts, prioritize communications, and challenge whether recovery criteria are specific enough.
Treasury / Payment Operations	Ability to validate queued payments, invoke dual-control review, determine which legitimate payments can continue, and operate manual continuity procedures.
Fraud / Financial Crime	Ability to triage payment exposure, coordinate hold/reject/recall actions, preserve an auditable record, and support external outreach.
Legal / Compliance / Privacy	Ability to advise on reporting thresholds, evidence handling, client/counterparty communications, regulatory obligations, and privilege-sensitive documentation.
SOC / Technical Response	Ability to scope credential misuse, isolate affected assets, preserve logs, coordinate with identity teams, and define safe reconnection criteria.

3. Scope

In scope	Out of scope
SWIFT-connected payment workstation and gateway Treasury payment creation, approval, queue review, and transmission processes Payment suppression and high-value transaction validation Fraud review and urgent recall coordination Security incident triage, containment, identity response, and recovery decision-making Internal escalation and external stakeholder communications Evidence preservation across workstation, gateway, identity, and payment logs	Execution of real production changes during the exercise Deep host-level forensic reconstruction beyond scenario evidence Product-specific SWIFT software administration procedures Jurisdiction-specific legal advice Vendor-side root cause confirmation beyond provided scenario facts Offensive exploit reproduction or malware development Actual contact with correspondent institutions or regulators

Facilitator boundary

Participants may discuss operational steps they would take in a real incident, but the exercise should not trigger actual payment suppression, network isolation, regulatory reporting, or customer/counterparty outreach.

4. Participants and Roles

Role	Primary responsibilities during the exercise	Key decisions
Security Operations Center (SOC)	Triage alerts; evaluate compromise indicators; recommend and execute technical containment; preserve evidence; coordinate endpoint, network, and identity response.	Incident severity; affected assets; containment method; safe reconnection recommendation.
Treasury / Payment Operations	Review queued messages; validate business legitimacy; suppress or hold suspicious payments; prioritize legitimate payment continuity.	Pause approvals; continue limited operations; invoke manual payment procedures.
Fraud / Financial Crime	Assess financial exposure; coordinate hold/reject/recall actions; support correspondent and beneficiary outreach; maintain fraud case chronology.	Recall initiation; fraud classification; exposure estimate.
Legal / Compliance / Privacy	Advise on regulatory, contractual, reporting, legal privilege, and recordkeeping implications; approve external language as appropriate.	Regulatory reporting; evidence-handling requirements; legal position on external statements.
Executive / Crisis Management Lead	Set risk appetite; approve broad payment freeze or restoration under residual risk; coordinate senior stakeholder decisions.	Business-wide payment interruption; risk acceptance; executive communications.
IT Infrastructure / Endpoint / IAM	Support workstation isolation, account disablement, session revocation, log collection, and reactivation controls.	Technical execution of isolation, credential reset, re-enablement, and monitoring changes.
Communications / Relationship Owners	Prepare internal messaging and externally coordinated notifications through approved channels.	Tone and timing of staff, client, correspondent, and board communications.
Facilitator / Scribe	Deliver injects; keep the scenario moving; capture decisions, assumptions, owners, gaps, and after-action items.	Exercise pacing; clarifying assumptions; observation scoring.

Decision ownership clarification

SOC owns technical containment recommendations and execution. Treasury and Fraud own payment-risk decisions, including queue validation and recall actions. Executive leadership owns acceptance of significant business disruption, such as a full payment freeze. This separation prevents the crisis cell from being treated as the technical operator and prevents the SOC from owning business payment risk.

5. Rules of Engagement

- This is a no-fault learning exercise focused on decision-making, coordination, and process validation.
- Participants should respond based on their current roles, authorities, and documented procedures.
- Real incidents take priority over the exercise.
- Assume the scenario is real unless the facilitator states otherwise.
- Reasonable assumptions may be made when documentation or tooling details are unavailable; assumptions must be stated aloud and captured by the scribe.
- Do not take live production actions, contact real counterparties, or file actual reports as part of the exercise.
- The purpose is not to test product-specific SWIFT administration expertise or offensive technical skill.
- Participants should challenge decision logic, not the scenario premise.

6. Scenario Background and Threat Narrative

Participant-facing narrative

The bank operates a high-trust treasury payment environment used to create, approve, and transmit SWIFT payment messages. Because the environment supports high-value payment flows, security and fraud controls depend on strict access control, message validation, segregation of duties, and rapid coordination between security and treasury operations.

A financially motivated intrusion crew has obtained access to a SWIFT-connected workstation by abusing compromised credentials and remote workstation access. Their objective is to create or queue unauthorized cross-border payment messages that appear plausible enough to survive initial review and move quickly through operational workflows.

The scenario begins when treasury operations discovers unusual queued payment messages outside expected business patterns. Participants must determine whether the activity is fraud, how broadly to contain, whether to disconnect SWIFT-connected systems immediately, how to validate pending messages, and how to coordinate recalls if suspicious messages have already moved beyond the bank.

Facilitator-only truth

- The adversary is financially motivated and focused on payment fraud, not disruption, ransomware, or public extortion.
- The SWIFT network itself is not compromised in this scenario. The risk comes from abuse of a bank-controlled high-trust workstation and associated credentials.
- The actor obtained valid domain credentials before the exercise start and used them to access the SWIFT-connected workstation through a legitimate remote access path.
- The actor performed limited discovery of the payment environment and payment queue before creating suspicious messages.
- The adversary did not deploy destructive malware and did not conduct broad customer data exfiltration in this scenario.

Exercise realism note

The added technical facts are deliberately high-level and defensive. They provide enough specificity for SOC, IAM, endpoint, treasury, and fraud teams to reason about detection and containment without providing operational attack instructions.

7. Key Scenario Facts and Added Assumptions

Facts carried forward from the provided scenario

- The participant organization is a banking entity operating SWIFT-connected treasury payment workflows.
- The targeted infrastructure is a SWIFT-connected payment workstation and gateway used to create, approve, and transmit payment messages.
- The threat actor is a crime-syndicate-style payment fraud intrusion crew.
- The central attack pattern is abuse of a compromised SWIFT-connected workstation to submit fraudulent messages.
- The first participant-visible event is discovery of multiple unusual cross-border payment messages queued outside normal business patterns.
- Participants must decide whether to disconnect SWIFT-connected systems immediately, how to verify queued messages, and how to coordinate recalls with counterpart institutions.
- Relevant courses of action include isolating high-trust payment endpoints and manually verifying or recalling high-value payment messages.

Added exercise facts to address the evaluation feedback

- A prior phishing event against a treasury support user created the initial foothold. This event is not the focus of the tabletop but explains how the attacker reached credential material.

- The actor harvested cached domain credential material from a non-SWIFT business endpoint and later abused a valid treasury operator account.
- The actor used an approved remote access path to reach a SWIFT-connected workstation, creating the appearance of legitimate operator activity.
- The actor performed limited discovery using native administrative tooling and reviewed payment workflow information to select plausible beneficiary routes and amounts.
- No custom malware persistence is assumed on the SWIFT workstation. The actor's persistence and evasion depend primarily on valid account abuse and blending with normal administrative activity.
- The fraud action culminates in creation, queueing, and partial release of unauthorized cross-border payment messages.

8. Technical Attack Lifecycle and Evidence Package

This section is the main cyber-accuracy enhancement. It defines a precise technical path before fraud execution and maps each stage to observable evidence and ATT&CK techniques. The facilitator should reveal evidence gradually through the injects.

Stage	Simulated time	Scenario action	Observable evidence for participants	ATT&CK alignment
1. Initial access	Day -6 to Day -5	A treasury support user receives a targeted phishing attachment and opens it, creating a short-lived foothold on a non-SWIFT endpoint.	Historical email-gateway alert; endpoint alert later correlated by SOC; no direct SWIFT impact yet.	T1566.001 Spearphishing Attachment; T1204.002 User Execution: Malicious File
2. Credential access	Day -5	The actor obtains cached domain credential material associated with treasury operations access.	EDR alert for credential-access behavior; unusual authentication attempts after the user's normal working hours.	T1003 OS Credential Dumping; T1003.001 LSASS Memory
3. Valid account abuse	Day -4 to 08:00	The actor uses a valid treasury operator account to authenticate to internal systems and avoid obvious access-denied events.	Successful logons from atypical source; MFA/session anomalies; access pattern inconsistent with user baseline.	T1078 Valid Accounts; T1078.002 Domain Accounts
4. Remote workstation access	07:40 to 08:05	The actor reaches the SWIFT-connected workstation through an approved remote access path.	Interactive logon on SWIFT-WS-07; remote session metadata; source jump host outside user's usual pattern.	T1021.001 Remote Desktop Protocol
5. Execution and discovery	08:05 to 08:20	Native administrative scripting is used to validate the host, inspect network connections, and orient to the payment workflow.	Script execution telemetry; system and network discovery events; review of payment application artifacts.	T1059.001 PowerShell; T1082 System Information Discovery; T1049 System Network Connections Discovery; T1213 Data from Information Repositories
6. Defense evasion / persistence approach	08:10 to 08:25	The actor avoids introducing obvious malware and instead blends into legitimate operator workflows using valid credentials and administrative-looking activity.	No new malware signature; logins and process names resemble legitimate administration but occur at unusual times.	T1078 Valid Accounts; T1036 Masquerading
7. Fraud execution	08:20 to 10:50	The actor creates multiple unauthorized cross-border payment messages and attempts to move at least one beyond the bank before queue suppression.	Unusual beneficiary, amount, and timing patterns; message queue artifacts; partial release status; approval-sequence anomalies.	T1657 Financial Theft

Evidence release plan

Inject	Evidence to release	Purpose
Inject 1	Unusual queued payment messages, abnormal timing, high-trust workstation source, and inconclusive operator outreach.	Drive incident declaration, queue suppression, and cross-functional triage.
Inject 2	Remote logon evidence, credential anomaly, native scripting/discovery telemetry, and uncertainty about gateway scope.	Force containment-scope decision and technical/business coordination.
Inject 3	One suspicious message released before full containment, beneficiary/correspondent details, and urgent recall window.	Test fraud-recovery ownership and external coordination.
Inject 4	Containment completed, credentials revoked, no additional suspicious queue entries, one recall pending, and restoration pressure.	Validate reconnection criteria, sign-off, residual risk, and reporting.

9. Evaluation Criteria and Success Metrics

Observers should score participant performance against objective criteria. The goal is not to grade individuals; it is to identify whether decision authorities, processes, tooling, and communications are sufficient for a real high-trust payment fraud incident.

Capability	Success metric / KPI	Strong performance evidence	Partial / gap indicators
Incident declaration and severity	Incident lead named and severity declared within 15 minutes of Inject 1.	Clear owner, severity rationale, fraud/cyber framing, and escalation path documented.	Unclear ownership; treated as routine payment issue; severity delayed.
Payment suppression	Suspicious messages paused, suppressed, or held within 20 minutes of decision trigger.	Treasury/Fraud authority identified; queue status confirmed; evidence preserved before changes.	Teams debate authority without action; payment queue state remains unknown.
Technical containment	Affected workstation, account, and active sessions isolated or disabled within 30 minutes of containment decision.	SOC/IAM/Endpoint actions coordinated; isolation does not destroy evidence.	Only broad shutdown considered; credentials left active; forensic capture ignored.
Credential response	Account reset/revocation scope defined within 45 minutes of confirmed valid-account abuse.	Human, service, and privileged paths considered; related sessions revoked.	Only password reset discussed; MFA/session/token revocation omitted.
Fraud recall	Counterpart hold/reject/recall outreach initiated within 15 minutes of release confirmation.	Fraud owns outreach through verified channels; Legal reviews language; status tracked centrally.	SOC expected to own recall; no verified counterparty contacts; message status unclear.
Business continuity	Break-glass or manual payment procedure assessed within 45 minutes of queue freeze.	Priority legitimate payments identified; dual controls and risk acceptance documented.	Continuity discussed informally; no manual controls or priority list.
Executive escalation	Executive/Crisis Lead receives exposure estimate, options, and recommendation within 30 minutes of Inject 3.	Decision memo includes risk, impact, recommended containment, and residual exposure.	Executives receive incomplete facts or no decision options.
Regulatory / legal assessment	Notification and reporting decision documented before exercise close.	Legal/Compliance capture thresholds, jurisdictional dependencies, and recordkeeping needs.	Regulatory discussion deferred without owner or due date.
Restoration governance	Minimum reconnection criteria and sign-off authority defined before reconnecting.	Enhanced monitoring, dual review, credential assurance, and residual risk approval included.	Restoration driven only by business pressure or vendor assurance.
Decision logging	Decision log includes owner, time, rationale, risk acceptance, and follow-up for each major decision.	Scribe captures decisions in real time and confirms actions at debrief.	Action items vague; no owner/date; chronology incomplete.

Observer scoring rubric

Score	Definition
3 - Strong	Metric achieved, ownership clear, decision rationale documented, and cross-functional coordination observed.
2 - Partial	Metric partly achieved, but with delays, unclear authority, missing documentation, or unresolved dependencies.
1 - Gap	Metric not achieved or participants could not identify the process, owner, evidence, or authority required.
N/A	Metric not tested because the exercise path did not reach the relevant decision point.

10. Exercise Timeline and Injects

Simulated time	Inject	Primary decision	Expected outcome
08:30	Inject 1 - Unusual Messages Queued	Is this a payment fraud incident requiring immediate queue controls?	Incident declared; cross-functional response activated; suspicious queue held.
09:30	Inject 2 - Containment Decision Point	Contain the single workstation or broader SWIFT path while maintaining critical payments?	Containment scope approved; credentials disabled; manual validation initiated.
11:00	Inject 3 - Suspicious Message Released	How quickly can recall and executive escalation occur?	Counterpart outreach launched; exposure estimate prepared; decision log updated.
15:00	Inject 4 - Recovery and Safe Restoration	What conditions are required before reconnecting high-trust payment assets?	Restoration criteria, controls, monitoring, and sign-off documented.

Inject 1 - Unusual Messages Queued

Simulated time	08:30	Incident stage	Detection and triage
Primary objective	Identify suspicious payment activity and initiate the right cross-functional response.		

Scenario narrative

Treasury operations identifies several unusual cross-border payment messages queued from a SWIFT-connected workstation. The messages were created outside normal business patterns and do not align with expected treasury activity for the day. At least two queued payments are high-value and directed to beneficiary institutions not commonly used by the bank.

Information provided to participants

- Multiple SWIFT payment messages are visible in queue, including two high-value payments over the internal enhanced-review threshold.
- Activity appears to originate from SWIFT-WS-07, a high-trust payment workstation.
- The timing is abnormal for the relevant business unit and does not align with the treasury payment calendar.
- Initial outreach to the named operator is inconclusive; the operator reports being away from the workstation during part of the message-creation window.
- It is not yet clear whether the messages have been transmitted, only queued, or partially approved.
- SOC sees a successful interactive logon to the workstation from an internal jump host outside the user's normal pattern.

Discussion questions

- Who owns the initial incident declaration and severity assessment?
- At what point does this become suspected payment fraud rather than a routine payment operations issue?
- What immediate actions reduce payment fraud risk without destroying evidence?
- Who is authorized to pause approvals or suppress queued payment messages?
- What controls confirm whether the messages are legitimate treasury activity?
- What notifications are required internally at this stage?
- What manual or break-glass payment procedures are available if the queue must be frozen?

Expected actions

- Declare a suspected cyber-enabled payment fraud incident and establish an incident lead.
- Start coordinated review between SOC, Treasury, Fraud/Financial Crime, Legal/Compliance, and IAM/Endpoint teams.
- Preserve workstation, gateway, authentication, approval, and message queue evidence.
- Halt approval or release of suspicious payments pending validation.
- Identify a single source of truth for message status, transaction amounts, beneficiaries, timestamps, and owners.
- Start scoping for credential misuse, abnormal workstation access, and related payment activity.

Facilitator notes

Push participants to identify who can stop payment release without creating uncontrolled business disruption. Clarify whether payment suppression requires dual approval and whether Fraud, Operations, or executive leadership must authorize a broader halt.

Observer evaluation checks

- Incident severity declared within 15 minutes.
- Payment queue status confirmed and suspicious messages held.
- Evidence-preservation owner identified before workstation changes.
- Treasury, Fraud, SOC, and Legal communications initiated.

Inject 2 - Containment Decision Point

Simulated time	09:30	Incident stage	Containment and business continuity
Primary objective	Force a decision between rapid isolation and operational continuity.		

Scenario narrative

Initial review indicates that at least some queued messages are unauthorized. SOC evidence shows valid-account abuse and remote interactive access to the SWIFT-connected workstation. Payment operations warns that a broad shutdown of the SWIFT-connected environment could delay legitimate, time-sensitive treasury settlements. Fraud teams request urgent validation and possible recall workflows for high-value messages.

Information provided to participants

- Confidence is increasing that the activity is unauthorized.
- The exact scope of workstation and credential compromise is not yet known.
- Remote Desktop session metadata shows access to SWIFT-WS-07 using a valid treasury operator domain account.
- Native administrative scripting and discovery telemetry were observed on the workstation, but no destructive malware is detected.
- Treasury leadership highlights potential liquidity and settlement impacts if all payment activity is paused.
- Fraud teams request immediate validation of high-value and unfamiliar beneficiary transactions.

Discussion questions

- Do you isolate only the SWIFT-connected workstation, or the broader gateway and associated payment path?
- What criteria determine whether limited payment operations can continue under heightened controls?
- Who validates queued messages, and what evidence is sufficient to classify them as unauthorized?
- When do you contact counterpart institutions to request hold, reject, or recall support?
- Which executives or crisis-management stakeholders must be engaged before a full payment freeze?
- What communications are required to business lines, finance, correspondent relationships, and internal leadership?
- How are compromised credentials, active sessions, and privileged access handled?

Expected actions

- Decide and document containment scope, including rationale and residual risk.
- Isolate affected endpoint(s), disable the suspected operator account, revoke sessions, and review related privileged access.
- Freeze or suppress suspicious queued messages and prevent further release pending manual validation.
- Initiate manual validation of pending high-value or unusual cross-border transactions under dual control.
- Coordinate external outreach readiness for potential hold, reject, or recall actions.
- Establish a controlled continuity plan for priority legitimate payments, including manual approvals and audit trail requirements.

Facilitator notes

This is the core exercise inflection point. Encourage debate around narrow versus broad isolation and whether the organization has realistic manual validation capability under time pressure. Ensure the SOC is not expected to own payment recall; Fraud/Treasury should own payment actions, with Legal supporting external language.

Observer evaluation checks

- Containment decision reached within 30 minutes of evidence release.
- Account/session revocation scope defined.
- Manual validation path identified with dual controls.
- Business risk acceptance documented if any payments continue.

Inject 3 - Suspicious Message Released Before Full Containment

Simulated time	11:00	Incident stage	Fraud response and external coordination
Primary objective	Test recall procedures and escalation under partial loss of control.		

Scenario narrative

Further review shows that one suspicious payment message was released before the queue freeze and is now awaiting downstream processing by a correspondent institution. Another queued message was stopped in time. Fraud analysts believe there is still a narrow window to request emergency hold or recall actions if outreach occurs immediately.

Information provided to participants

- One suspicious message left the queue before full containment.
- Beneficiary and intermediary details are available, but originator and approval-chain details require confirmation.
- The message amount is material enough to require executive awareness under internal thresholds.
- Payment operations is under pressure to resume legitimate activity.
- Executives request an exposure estimate and clear options within 30 minutes.
- Legal asks that external statements be coordinated to preserve evidence and avoid premature admissions beyond confirmed facts.

Discussion questions

- What is the bank's immediate recall process, and who owns external outreach?
- What evidence must be collected before asserting the transfer is fraudulent?
- How do Legal, Compliance, Fraud, Treasury, and correspondent relationship owners coordinate messaging?
- What is the threshold for executive crisis escalation and board awareness?
- How do you maintain an auditable chain of decisions while moving quickly?
- What is the communication posture if counterpart institutions or internal stakeholders request additional details?

Expected actions

- Launch urgent interbank outreach for hold, reject, or recall actions using verified channels.
- Establish a single source of truth for message status, beneficiaries, intermediaries, amounts, and timestamps.
- Escalate to executives with options, impacts, recommended actions, and residual uncertainty.
- Continue scoping for additional fraudulent messages, compromised approvals, or related credential misuse.
- Coordinate Legal/Compliance review of reporting, suspicious activity, and recordkeeping requirements.
- Document all decisions, owners, timestamps, risk acceptance, and evidence used.

Facilitator notes

Probe whether participants distinguish technical containment from fraud-recovery workflow ownership. Many teams can isolate a workstation but struggle to operationalize time-critical recall actions and verified counterparty communications.

Observer evaluation checks

- Recall/hold outreach initiated within 15 minutes of release confirmation.
- Executive decision briefing delivered within 30 minutes.

- Fraud case chronology and decision log started.
- External communications owner and approval path identified.

Inject 4 - Recovery and Safe Restoration

Simulated time	15:00	Incident stage	Recovery and post-incident obligations
Primary objective	Validate restoration criteria and post-incident governance.		

Scenario narrative

The compromised workstation has been isolated, associated credentials have been revoked, and no additional suspicious messages are found in the queue. One recall request remains under review by a counterpart institution. Business leadership wants SWIFT-related operations restored quickly, but security advises that reconnecting high-trust payment assets before minimum assurance steps are completed may introduce further risk.

Information provided to participants

- Initial containment appears effective.
- No additional suspicious messages are identified after expanded queue review.
- Credential revocation and session termination are complete for the primary suspected account.
- Endpoint and gateway logs are preserved for forensic review.
- A limited set of legitimate high-priority payments remains delayed.
- Leadership requests a recommendation on restoration timing and residual risk.

Discussion questions

- What minimum evidence or assurance is required before reconnecting or restoring the payment environment?
- Who signs off on service restoration and under what authority?
- What monitoring, dual-review, or compensating controls must be added during the recovery period?
- What reporting, board-level, or regulatory obligations should be considered?
- What lessons learned should be captured immediately after the exercise scenario ends?
- What remediation items must be completed before returning to normal payment operations?

Expected actions

- Define restoration entry criteria and decision authority.
- Confirm no active sessions, disabled compromised credentials, preserved evidence, and clean queue review.
- Use enhanced monitoring and dual-review controls during reactivation.
- Document incident chronology, decisions, residual risks, and sign-offs.
- Prepare post-incident reporting and lessons learned.
- Assign remediation owners for access governance, queue review, anomaly detection, payment continuity, and recall readiness controls.

Facilitator notes

Focus on disciplined restoration, not speed alone. The key learning is whether the organization can articulate what 'safe to reconnect' means for a high-trust payment environment and who can accept residual risk.

Observer evaluation checks

- Restoration criteria are specific, testable, and approved before reconnecting.
- Enhanced monitoring and dual approval are defined for the stabilization period.
- Regulatory and board reporting decision is documented.
- After-action owners and due dates are assigned.

11. Key Decision Points

Decision point	Trigger	Recommended owner	Decision record should include
Formal incident escalation	Unusual SWIFT messages from high-trust workstation outside normal business pattern.	SOC incident lead with Treasury/Fraud input.	Severity, rationale, impacted services, first actions, escalation contacts.
Payment queue suppression	Potential unauthorized payments in queue or pending approval.	Treasury/Payment Operations with Fraud concurrence.	Affected messages, suppression method, business impact, evidence preserved.
Workstation versus gateway containment	Valid-account abuse and uncertain scope of SWIFT workstation compromise.	SOC recommends; Executive/Crisis Lead approves broad business-impacting isolation.	Assets isolated, rationale, residual risk, continuity controls.
Credential revocation scope	Evidence of valid-account abuse or remote access anomaly.	SOC/IAM.	Accounts, tokens, sessions, service accounts, privileged access, MFA status.
Counterparty outreach	Suspicious message released or potentially transmitted.	Fraud/Financial Crime with Treasury and Legal.	Counterparty contacts, verified channels, message identifiers, recall status.
Limited payment continuity	Legitimate time-sensitive payments delayed by containment.	Treasury with Executive risk acceptance and Legal/Compliance awareness.	Priority criteria, manual controls, dual approval, monitoring, risk acceptance.
Restoration	Containment complete and business requests reactivation.	SOC recommends; Executive/Crisis Lead approves; Treasury accepts operational controls.	Entry criteria, monitoring controls, sign-offs, residual risk, rollback plan.

12. Technical and Business Impacts

Technical impacts	Business impacts
Potential compromise of a high-trust SWIFT-connected workstation Valid-account abuse and possible credential misuse Unauthorized message creation or queue manipulation Potential remote access path misuse Need for rapid evidence preservation across endpoint, identity, gateway, and payment logs Need to validate absence of additional persistence before restoration	Delayed treasury and settlement operations Potential unauthorized cross-border fund movement Liquidity, settlement, and correspondent-bank relationship impacts Client, counterparty, and market confidence risk Regulatory, legal, audit, and board reporting implications Executive pressure to restore critical payment activity quickly

Controls and capabilities tested

- Segregation of duties for payment creation, approval, queue release, and recall.
- Identity controls for high-trust workstations, privileged access, session revocation, and MFA enforcement.
- Detection of anomalous access to payment endpoints and message queues.
- Operational continuity for priority payments under enhanced dual review.
- Evidence preservation and forensic readiness for high-trust payment assets.
- Regulatory and legal assessment under financial fraud uncertainty.

13. Facilitator Guide

Timebox	Activity	Facilitator focus
10 minutes	Introduction, objectives, rules of engagement	Set no-fault tone, clarify no live actions, confirm roles.
15 minutes	Inject 1 discussion	Drive incident declaration, payment queue risk, initial evidence preservation.
20 minutes	Inject 2 discussion	Force containment scope, credential response, manual continuity decision.
20 minutes	Inject 3 discussion	Test recall workflow, executive escalation, external communications.
15 minutes	Inject 4 discussion	Validate restoration criteria, sign-off, reporting, enhanced monitoring.
10 minutes	Debrief and action assignment	Capture strengths, gaps, owners, due dates, and scorecard results.

What to listen for

- Clear ownership of payment-halt authority and queue suppression.
- Coordination between SOC, Treasury, Fraud, Legal, IAM, and executive leadership.
- Understanding that technical containment and fraud recall are related but separately owned workflows.
- Realistic manual payment continuity procedures with dual controls.
- Verified correspondent-bank outreach readiness.
- Restoration criteria that are specific, testable, and owned.
- Evidence capture before reimaging, reconnecting, or changing high-trust systems.

Common gaps to surface

- Unclear authority to suppress queued payments or delay legitimate settlement activity.
- No rehearsed interbank recall process or verified contact path.
- Weak segregation of duties around payment creation, approval, and release.
- Overreliance on the SOC for business payment decisions.
- Business pressure to restore before minimum assurance is achieved.
- Insufficient decision logging for later regulatory, audit, and legal review.
- Credential response limited to password reset without session, token, service account, or privileged access review.

Facilitator escalation prompts

- Ask what evidence would change the containment decision from workstation-only to gateway-wide.
- Ask who can accept delayed settlement risk if legitimate payments remain paused.
- Ask what the organization would say if a correspondent bank requests written confirmation that a message is fraudulent.
- Ask whether the crisis cell receives a recommendation from SOC and Treasury/Fraud or tries to operate the technical response directly.
- Ask what 'safe to reconnect' means in measurable terms.

14. Debrief and Lessons Learned

Use the closing discussion to identify strengths, gaps, and specific improvements. The facilitator should distinguish between process gaps, tooling gaps, authority gaps, communications gaps, and training needs.

Debrief prompts

- What was the first moment when the organization should have treated the event as suspected payment fraud rather than a routine system issue?
- Did participants know who could stop payment release immediately?
- Were communications between SOC, Treasury, Fraud, Legal, and executive leadership clear and fast enough?
- Could the organization continue priority payments safely under manual or break-glass procedures?
- Were recall contacts, message identifiers, and verified communication channels available?
- Was the credential response broad enough for valid-account abuse?
- What changes are needed in queue review, alerting, privilege control, anomaly detection, or correspondent-bank coordination?
- What restoration controls should remain in place after reconnecting?

Suggested after-action outputs

- Decision log and incident timeline.
- Gaps and risks register.
- Action plan with owners, due dates, dependencies, and risk priority.
- Recommendations for fraud controls, privileged access, anomaly detection, and future exercises.
- Updates to runbooks for payment suppression, recall, manual continuity, evidence preservation, and restoration.

Finding	Risk	Owner	Due date	Success criterion

15. Glossary

Term	Meaning in this exercise
SWIFT	A global financial messaging network used by financial institutions to exchange payment and transaction instructions.
SWIFT-connected workstation	A high-trust endpoint used to create, approve, or submit payment messages through internal SWIFT-related workflows.
Gateway	The internal payment path or interface connecting the bank's payment environment to SWIFT-related messaging services.
SOC	Security Operations Center responsible for technical incident triage, containment coordination, and monitoring.
SIEM	Security Information and Event Management system used to aggregate and analyze security logs.
EDR	Endpoint Detection and Response tooling used to monitor endpoint behavior and support containment.
IAM	Identity and Access Management function responsible for account, privilege, session, and authentication controls.
RDP	Remote Desktop Protocol or equivalent approved remote interactive access path.
MFA	Multi-factor authentication.
Break-glass procedure	Pre-approved emergency process used to maintain critical operations when normal systems are impaired.
Recall / hold / reject	Fraud-recovery actions requested through correspondent or beneficiary institutions to stop or reverse suspicious payment processing where possible.
Single source of truth	A consolidated record of message status, exposure, decisions, owners, and timestamps used during crisis coordination.
Residual risk	Remaining risk after containment or compensating controls, explicitly accepted by authorized leadership.

16. Optional Visuals for Facilitation

The following visuals can be placed on slides, a whiteboard, or a one-page handout if the exercise is run live. They are included here as facilitation aids and may be adapted to local terminology.

Scenario timeline visual

Day -6	Day -5	07:40	08:30	09:30	11:00	15:00
Initial foothold	Credential access	Remote access to SWIFT-WS-07	Unusual messages found	Containment decision	One message released	Recovery decision

Functional swimlane prompts

Function	Detection	Containment	Fraud response	Recovery
SOC	Triage workstation/login telemetry.	Recommend isolation, preserve evidence, revoke sessions with IAM.	Continue scoping; support technical facts for Fraud/Legal.	Confirm assurance criteria and monitoring.
Treasury	Validate business legitimacy of queued messages.	Suppress queue; prioritize critical legitimate payments.	Provide payment identifiers and operational context.	Approve controlled reactivation and backlog plan.
Fraud	Assess whether pattern indicates payment fraud.	Prepare hold/recall playbook.	Own verified counterparty outreach and exposure tracking.	Close fraud case chronology and remediation actions.
Legal / Compliance	Advise on evidence, reporting, and notification thresholds.	Review risk acceptance and external messaging.	Approve recall language and reporting posture.	Support post-incident report and governance review.
Executive / Crisis Lead	Receive severity and impact briefing.	Approve broad payment freeze or limited continuity risk.	Review exposure estimate and options.	Accept residual risk and sign off restoration.

17. MITRE ATT&CK Mapping

This final section maps the revised scenario to MITRE ATT&CK Enterprise tactics and techniques. Techniques are included only where they are explicit facts in this enhanced exercise design. The mapping is intended for defensive discussion, detection coverage review, and after-action planning; it is not an adversary emulation plan.

Tactic	Technique	Scenario behavior reflected	Defensive discussion / evidence
Initial Access	T1566.001 - Phishing: Spearphishing Attachment T1204.002 - User Execution: Malicious File	A prior phishing event against a treasury support user created the initial foothold. This is background context, not a participant execution task.	Email gateway evidence, endpoint alert history, user reporting, and whether phishing context changes response scope.
Credential Access	T1003 - OS Credential Dumping T1003.001 - LSASS Memory	The actor harvested cached credential material before accessing the SWIFT-connected workstation.	EDR telemetry, credential exposure assessment, privileged account review, password/session/token revocation.
Initial Access / Persistence / Defense Evasion	T1078 - Valid Accounts T1078.002 - Domain Accounts	The actor used a valid treasury operator domain account to blend into normal activity and maintain access without deploying obvious malware.	Authentication logs, impossible/atypical access, MFA telemetry, account/session revocation, least privilege.
Lateral Movement	T1021.001 - Remote Desktop Protocol	The actor used an approved remote interactive access path to reach the SWIFT-connected workstation.	RDP/session metadata, jump host access records, privileged workstation access policies.
Execution	T1059.001 - Command and Scripting Interpreter: PowerShell	Native administrative scripting was used to validate the host and orient within the payment environment.	Script block/process telemetry, unusual parent-child process relationships, administrative tool baselining.
Discovery	T1082 - System Information Discovery T1049 - System Network Connections Discovery T1213 - Data from Information Repositories	The actor inspected the workstation, network connections, and payment workflow information to identify the SWIFT path and plausible payment details.	Discovery command telemetry, payment application access logs, queue review logs, repository access alerts.
Defense Evasion	T1036 - Masquerading	Actor activity was designed to look like legitimate administrative or operator behavior; no custom malware persistence is assumed.	Process naming, unusual timing, mismatch between operator behavior and access logs, enhanced monitoring.
Impact	T1657 - Financial Theft	The actor attempted unauthorized fund movement by creating, queueing, and partially releasing fraudulent cross-border payment messages.	Payment anomaly detection, beneficiary review, recall readiness, fraud case management, correspondent bank coordination.

Excluded or intentionally not assumed

- No compromise of the SWIFT network itself is assumed.
- No destructive malware, ransomware, public extortion, or broad client data exfiltration is assumed.
- No persistent malware is assumed on the SWIFT workstation; persistence is represented through valid-account abuse.
- No vendor-side compromise is assumed unless the facilitator explicitly introduces such an inject in a future variant.
- T1539 - Steal Web Session Cookie is not mapped because the revised scenario uses OS credential dumping and domain-account abuse as the defined credential path.

Detection and control themes for after-action planning

- High-trust workstation access baselining and alerting.
- Strict MFA and session management for payment operators and remote access paths.
- Least privilege and segregation of duties for payment creation, approval, and release.
- Out-of-band validation for unusual beneficiaries and high-value payments.
- EDR/SIEM visibility for credential access, scripting, remote sessions, and payment queue manipulation.
- Rehearsed interbank hold/reject/recall procedures with verified contacts and message identifiers.

End state

The exercise should end with a validated decision model, a scored observer sheet, and a remediation action plan covering payment controls, identity controls, technical detection, recall readiness, and restoration governance.